

guzel.net.tr

Iyi

84

/ 100 puan

Puan Dokumu

SPF

14 /20

DMARC

20 /25

DKIM

20 /20

MX

10 /10

SSL

20 /25

E-posta ve SSL Guvenlik Kontrolleri

! SPF Kaydi	20 puan
v=spf1 a mx ip4:31.192.212.2 ip4:31.192.212.32 ip4:185.106.211.31 ip4:31.192.212.38 includ	
+ DMARC Politikasi	25 puan
v=DMARC1; p=quarantine; rua=mailto:abuse@guzel.net.tr	
+ DKIM Imzasi	20 puan
dkim, default	
+ MX Kayitlari	10 puan
pmg2.guzel.net.tr	
+ SSL/TLS Sertifikasi	25 puan
Let's Encrypt - 38 gun gecerli	

Web Sunucu Guvenlik Basliklari

Toplam skor: 3/5 baslik

- HSTS (Strict-Transport-Security)
- + X-Frame-Options (clickjacking korumasi)
- + X-Content-Type-Options
- Content-Security-Policy (CSP)
- + Referrer-Policy

Risk Istihbarati

- + Veri Sizintisi (HIBP)
Temiz — sizinti kaydi yok
- + Kara Liste (DNSBL)
Temiz — hicbir kara listede yok
- + URLhaus Zararli URL
Temiz — zararli URL listesinde yok
- + USOM Ulusal Kara Liste
Temiz — USOM listesinde yok



Golge BT Tespiti (Shadow IT)

5 servis — 0 yuksek riskli (Google Analytics / Tag Manager, Tawk.to, WordPress, Cloudflare...)

Katman 1 Tehdit Istihbarati



VirusTotal Domain Reputation

Temiz — 70+ motor zararli isaretlememi. Reputation skoru: 0



IP Kotuye Kullanım Gecmisi

Guven skoru: %0 — son 90 gunde 0 rapor. Konum: US, Cloudflare, Inc.



Internet Maruziyeti Analizi

13 CDN beklentisi (US, Cloudflare, Inc.)

MITRE ATT&CK Saldin Senaryolari

Genel Tehdit Seviyesi: Düşük

SPF yapılandırması eksik olup phishing saldırılarına karşı e-posta güvenliği zayıftır. HTTP başlık eksiklikleri (3/100) ve Shadow IT uygulamaları veri sızıntısı riskini artırmaktadır.

YÜKSEK

[Yüksek]

SPF Eksikliğinden Kaynaklanan Kimlik Avı Saldırısı

Giris Noktasi: Saldırgan, guzel.net.tr etki alanında hareket ettirilen sahte e-postaları gönderir çünkü SPF kaydı eksiktir.

Saldiri Zinciri:

- Keşif: Saldırgan guzel.net.tr için SPF kaydı sorgulanır ve FAIL sonucu alır; alan adı e-posta kimlik doğrulamasına karşı korunmasız görül
- İlk Erişim: Sahte e-postalar (admin@guzel.net.tr görünümü) müşteri ve çalışanlara gönderilir; DMARC p=quarantine politikası var olsa da,
- Yanal Hareket/Kalıcılık: Hedef kişi e-postadaki kötü amaçlı bağlantıya tıklar veya kimlik bilgilerini yanıltıcı forma girer; elde edilen
- Etki: İş e-posta hesapları ele geçirilir; müşteri verilerine erişim sağlanır; şirket temsilen sahte iletişim yapılır.

Etki: Müşteri ve çalışan kimlik bilgilerinin ele geçirilmesi; finansal dolandırıcılık; şirket itibarına zarar.

KVKK: Kişisel veri ihlali söz konusu olması halinde KVKK m.28 kapsamında hasar tazminatı ve m.109 kapsamında 10-50 milyon TL idari para cezası riski.

MITRE: T1598 Phishing | T1566 E-posta tabanlı İlk Erişim

ORTA

[Yüksek]

Shadow IT Uygulamalarından Veri Sızıntısı

Giris Noktasi: Google Analytics, Tag Manager, Tawk.to ve diğer bulut hizmetleri site trafiği ve kullanıcı davranışını takip eder; bu uygulamaların sürümleri bilinmemektedir ve

Saldiri Zinciri:

- Keşif: Saldırgan sitedeki JavaScript etiketlerini analiz eder ve kullanılan analitik/sohbet araçlarını tanımlar; API belgelendirmeleri in
- İlk Erişim: Eğer Tag Manager veya Analytics API anahtarı kod içinde açıkta ise, saldırgan bunu repo/ağ trafiğinden elde eder; alternatif
- Yanal Hareket/Kalıcılık: Saldırgan Shadow IT uygulamalarının yönetim paneline erişerek hesapları modifiye eder, veri akışını kendi sunucu
- Etki: Müşteri navigasyon verileri, form girdileri, sohbet transkriptleri izinsiz toplanır ve satılır; sitedeki özel veri ele geçirilir.

Etki: Müşteri hareketleri, kişisel verileri ve kurumsal stratejik bilgiler izinsiz olarak toplanır; rekabet zararı ve itibar kaybı.

KVKK: Kişisel veri işleme yasal dayanağı olmadan yapılması halinde KVKK m.28 kapsamında hasar tazminatı ve m.109 kapsamında 10-50 milyon TL idari para cezası riski.

MITRE: T1592 Sosyal Medya ve İnternet Ortamında Bilgi Toplama | T1528 Erişim Tokeni Hırsızlığı

Oncelikli Aksiyon Listesi

1. SPF kaydı oluşturun ve DNS TXT kaydına ekle

SPF FAIL durumu phishing ve kimlik avı saldırılarına karşı en yüksek riski oluşturmaktadır; saldırganlar e-posta kimlik doğrulamasını atlatabilir.

2. Shadow IT uygulamalarının (Google Analytics, Tag Manager, Tawk.to, WordPress, jQuery) erişim izinlerini ve API anahtarlarını inceleyip yetki ve sürüm kontrolünü sağla

Sürümler bilinmediği ve erişim kontrol mekanizmaları doğrulanmadığı için müşteri verilerinin izinsiz toplanması veya sızması riski yüksektir.

3. HTTP başlıklarını (X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, CSP) ekleyerek başlık güvenliğini 3/100'den iyileştir

Zayıf HTTP başlıkları clickjacking, MIME sniffing ve XSS saldırılarına karşı savunmasızlık gösterir ve saldırı vektörünü artırır.

